

Poonawalla Fincorp Limited

Information Security Policy

Effective Date: 17.10.2025

Approval Date: 17.10.2025

Version No.: 12.0

Approved By: Board of Directors

Policy Owner: Information Security
team

This document is Internal in nature and supersedes any existing Policy on Information security policy in the Company and should be read in conjunction with the most recent policies and procedures documented.



INFORMATION SECURITY POLICY

Document review and approval**Document Control**

Document Name	Information Security Policy
Document Version	12.0
Frequency of review	Yearly
Effective Date	17.10.2025
Reviewed by	Chief Information Security Officer
Approved by	Board of Directors
Policy Owner	Information Security Team

Version Control

Date	Version	Change Description (in brief)
		The name of the Company changes to Poonawalla Fincorp Limited w.e.f. 22.07.2021
27.10.2021	7.0	To align with the regulatory requirements
21.10.2022	8.0	- Added mandatory Information Security team training - Updated the change management classification as standard, normal and emergency - Enhance the PII definition
20.10.2023	9.0	Minor Document Update
18.01.2024	10.0	To align with regulatory requirements
25.10.2024	11.0	- ISC Committee Re-constitution - Updation of Remote Access and cryptographic controls
17.10.2025	12.0	- Addition on AI security Policy - Updation on encryption type - Revision of Responsibilities of the CISO / Head of Information Security - Updation of CHRO/ HR Head as an invitee to ISC once in year or as and when required.



Table of Contents

Introduction.....	8
1. Organization of Information Security	8
1.1 Internal Organization	8
1.2 Information Security Committee (ISC).....	9
1.3 Information Security Policy Statement	9
1.4 Information Security Control Objectives.....	9
1.5 Compliance with the Information Security Policy.....	10
1.6 Review of the Information Security Policy.....	10
1.7 Segregation of Duties.....	10
1.8 Responsibilities of CISO/ Head Information Security.....	11
1.9 Responsibilities of Information Security Team.....	12
1.10 Responsibilities of Information Asset Owner	12
1.11 Responsibilities of Application Owner	13
1.12 Confidentiality Agreements	13
1.13 Contact with Authorities	13
1.14 Contact with Special Interest Groups.....	13
1.15 External Parties	14
1.15.1 Identification of Risks Related to External Parties	14
1.15.2 Addressing Security in Third Party Agreements.....	14
1.15.3 Addressing Security When Dealing with Customers.....	15
2 Acceptable Usage Policy	15
2.1 General Use.....	15
2.2 Securing Proprietary Information	16
2.3 E-mail Usage.....	16
2.4 Internet Usage	17
2.5 Remote Access Usage.....	17
2.6 File Servers Usage	17
2.7 Printers Usage	18
2.8 Software Usage	18
2.9 External Storage Devices	18
2.10 Prohibitive System and Network Activities.....	18
2.11 Incident Reporting.....	19
3 Access Control.....	19
3.1 Business Requirement for Access.....	19



3.1.1	User Access Management.....	20
3.1.2	User Registration.....	20
3.1.3	Emergency access	21
3.1.4	Role based Access Control.....	21
3.1.5	Privilege Management	21
3.1.6	Personnel Security.....	22
3.2	User Responsibilities.....	24
3.2.1	Password Use	24
3.2.2	Unattended User Equipment	25
3.2.3	Clear Desk and Clear Screen Policy	25
3.2.4	Secure Log-on Procedures	26
3.3	Mobility & Remote Computing	26
3.4	Logging and Monitoring	26
3.4.1	Monitoring System Use	27
3.4.2	Protection of Log Information	27
3.4.3	Administrator and Operator Logs	27
3.4.4	Fault Logging.....	28
3.4.5	Clock Synchronization.....	28
4	Cryptography	28
4.1	Policy on the use of Cryptographic controls	28
5	Information System Acquisition, Development and Maintenance.	28
5.1	Security Requirements of Information Systems	29
5.1.1	Security Requirements Analysis and Specification	29
5.2	Security of System Files	30
5.2.1	Control of Operational Software.....	30
5.2.2	Protection of System Test Data.....	31
5.2.3	Access Control to Program Source Code for Applications Developed in-house.....	31
5.3	Security in Development and Support Processes.....	31
5.3.1	Change Control Procedures.....	31
5.3.2	Review of the Proposed Design	31
5.3.3	Testing.....	32
5.3.4	Technical Review of Applications after Operating System Changes	32
5.3.5	Restrictions on Changes to Software Packages.....	32
5.3.6	Outsourced Software Development	32
6	Change Management	32

7	Incident Management	33
7.1.1	Security Incident Management	33
7.1.2	Scope.....	33
7.1.3	Reporting Security Events and Weaknesses	34
7.1.4	Management of Incidents.....	34
7.1.5	Learning from Security Incidents.....	35
7.1.6	Collection of Evidence.....	35
8	Information Backup and Archival.	36
8.1	Backup	36
8.2	Information Backup	36
8.3	Information Backup Testing	36
9	Asset Management	37
9.1	Responsibility for Assets	37
9.1.1	Inventory	37
9.1.2	Ownership of Assets	37
9.1.3	Asset Classes.....	37
9.1.4	Physical asset Labelling.....	38
9.1.5	Acceptable Use of Assetss	38
9.1.6	Asset Movement	38
9.1.7	Maintenance and Upgrades.....	38
9.1.8	Classification of Information Assets.....	38
9.2	Information Labelling and Handling.....	39
9.3	Protection of Intellectual Property	39
9.3.1	Disposal of Assets.....	39
9.3.2	Periodic Review.....	39
10	Compliance Policy.....	39
10.1	Compliance with Legal Requirements.....	40
10.2	Compliance with Security Policies, Standards and Technical Compliance.....	40
10.2.1	Compliance with Security Policies and Standards.....	40
10.2.2	Technical Compliance Checking	40
10.2.3	Protection of records	40
10.2.4	Privacy and protection of personally identifiable information.....	41
10.3	Information Systems Audit Considerations	41
10.3.1	IA Charter	42
10.3.2	Protection of Information Systems Audit Tools	42



11 Physical Security	43
11.1 Secure Areas	43
11.2 Physical Security Perimeter	43
11.3 Physical Entry Controls	43
11.4 Securing Offices, Rooms and Facilities	44
11.5 Protecting Against External and Environmental Threats	44
11.6 Working in Secure Areas	44
11.7 Public Access, Delivery, and Loading Areas	44
11.8 Equipment Security	45
11.9 Equipment Siting and Protection	45
11.10 Supporting Utilities	45
11.11 Equipment Maintenance	45
11.12 Security of Equipment Off-Premises	46
11.13 Secure Disposal or Re-Use of Equipment	46
12 Information Security Risk Assessment	46
12.1 Risk Management Process	47
12.2 Risk Assessment	47
12.3 Risk Identification	47
12.4 Risk Evaluation	47
12.5 Risk Treatment	48
13 Cloud Computing	48
14 Definition	51



Introduction

1. Organization of Information Security

Overview:

The Information Security Policy defines appropriate responsibilities, authority and relationships to manage information security in Poonawalla Fincorp Limited ("PFL")

The Information Security Policy establishes a security management framework for implementation within PFL. Hence, it is important that the programme is consistently implemented across PFL. This shall entail commitment from management and formulation of an information security governance structure to drive the Policy. Management shall provide overall direction to the programme, approve policies and procedures, assign the various roles, co-ordinate and review the implementation of the Policy.

1.1 Definition:

Cyber - Relating to, within, or through the medium of the interconnected information infrastructure of interactions among persons, processes, data, and information systems.

Cyber event – Any observable occurrence in an information system. Cyber events sometimes provide indication that a cyber incident is occurring.

Cyber security - Preservation of confidentiality, integrity and availability of information and/or information systems through the cyber medium. In addition, other properties, such as authenticity, accountability, non-repudiation and reliability can also be involved.

Cyber incident shall mean a cyber event that adversely affects the cyber security of an information asset whether resulting from malicious activity or not.

Cyber-attack - Malicious attempt(s) to exploit vulnerabilities through the cyber medium to damage, disrupt or gain unauthorized access to assets.

Information Asset - Any piece of data, device or other component of the environment that supports information-related activities. Information Assets include information system, data, hardware and software.

Information System - Set of applications, services, information technology assets, Information and Communication Technology (ICT) systems or other information-handling components, which includes the operating environment and networks.

IT Risk - The business risk associated with the use, ownership, operation, involvement, influence and adoption of IT within an enterprise.

Privileged User - Refers to user who, by virtue of function, and/or role, has been allocated powers within an information system, which are significantly greater than those available to the majority of users.

1.2 Internal Organization

Objective: To maintain the security of the organisation's information and information processing facilities that are accessed, processed, and communicated.

1.3 Information Security Committee (ISC)

Composition of Information Security Committee

S.No.	Name of the members	Position in the Committee
1	Chief Risk Officer	Chairperson
2	Chief Information Security Officer	Member
3	Chief Technology Officer	Member
4	Chief Compliance Officer	Member
5	Chief Credit & Analytics Officer	Member
6	Consumer Business Officer	Member
7	Commercial Business Officer	Member

* Chief Human Resource Officer (CHRO)/ HR Head will be invited to ISC meeting as an invitee at least on annual basis or as and when required.

Terms of Reference of the Information Security Committee

1. Development of information/ cyber security policies, implementation of policies, standards and procedures to ensure that all identified risks are managed within the RE's risk appetite.
2. Approving and monitoring information security projects and security awareness initiatives.
3. Reviewing cyber incidents, information systems audit observations, monitoring and mitigation activities.
4. Updating ITSC and Managing Director periodically on the activities of ISC.

1.4 Information Security Policy Statement

PFL shall endeavour to ensure that the information and the information processing facilities are protected and made secure from all known security threats arising both internally and externally.

1.5 Information Security Control Objectives

Information Security at Organisation. driven by the following objectives:

- Protection of information against unauthorized access by maintaining its confidentiality.



- Ensuring the integrity of information. Integrity relates to the accuracy and completeness of information as well as to its validity in accordance with business values and expectations.
- Ensuring the availability of information to those who are authorized and require it. Availability relates to information being available when required by the business process now and in the future. It also concerns the safeguarding of necessary resources and associated capabilities.
- Meeting the legal, regulatory, and legislative requirements.
- Imparting information security awareness training to all staff.
- Reporting and investigation of security breaches.
- Effective Role definition for key employees to avoid conflict in duties and areas of responsibility.
- Managing Information security risk by integrating Information security governance in the overall enterprise governance framework of the organization; and
- Ensuring Continual Improvement to the information security management system.

1.6 Compliance with the Information Security Policy

The Policy is applicable to all employees, contractors and third-party vendors who have access to PFL information resources herein after referred to as “Users”. Any non-compliance to the policy would lead to disciplinary action including termination with the possibility of legal action being initiated against the individual(s) concerned as applicable by the relevant legislation.

1.7 Review of the Information Security Policy

The Information Security Policy shall be reviewed on an annual basis or as and when significant changes occur.

1.8 Segregation of Duties

Duties and areas of responsibility shall be segregated in order to reduce opportunities for unauthorized or unintentional modification or misuse of information assets.

Responsibilities to be performed by the role holders in the development, processing, administration or management of Organisation's information systems shall be identified, documented, approved and users shall be accordingly set up with the approved privileges.

User account creation requests and access entitlement requests shall not be self-approved by the requestor. Business managers or their delegates cannot review or approve their own access entitlements.

Conflicting roles and users shall be identified. Assignment of such conflicting roles shall be prohibited. Following is an indicative list of conflicting duties:

- A single user responsible for implementing and approving their own transaction, such as lack of dual control or 'maker-checker'.



- Application development/ testing team carrying out application administration in production environment.
- Users carrying out log monitoring for their own machines.
- Server or network administrators carrying out database administration; and
- Network and security device being carried out by single operational team.

When conflicting roles need to be assigned to a user, the following controls shall be implemented in consultation with Information Security team:

- Valid business justification for the exception request shall be documented.
- Risks shall be identified by Information Security team that may arise because of conflicting roles.
- Information Security team shall approve or reject the request based on the risk assessment.
- Mitigating or compensatory controls shall be identified and implemented for requests that are approved by Information Security team.
- User IDs with such conflicting roles shall be logged.
- Monitoring of activities through audit trails, exception reporting, reconciliation, and transaction logs; and
- Conflicting roles shall be reviewed at least once a year by respective functional heads and approved by CTO/CIO. A formal approval for continuation of conflicting roles shall be obtained after the yearly review.

For any transition of personnel from one function to another which may be conflicting (i.e. if a person may retain more than one conflicting role), it shall be ensured that:

- All access privileges are revoked from the previous functional role; and
- All requisite accesses that are required for new role are identified and granted.

Conflicting duties that cannot be segregated on IT systems owing to business requirements shall be documented and submitted for approval to the respective line manager, head of the business unit and Information Security team.

1.9 Responsibilities of CISO/ Head Information Security

A senior level executive (preferably in the rank of a General Manager or an equivalent position) shall be designated as the Chief Information Security Officer (CISO). The CISO shall not have any direct reporting relationship with the Head of IT Function and shall not be given any business targets while ensuring the following:

- The CISO has the requisite technical background and expertise.
- She/He is appointed for a reasonable minimum term;
- The CISO's Office is adequately staffed with people having necessary technical expertise, commensurate with the business volume, extent of technology adoption and complexity; and
- (iv) The budget for the information/ cyber security is determined keeping in view the current/ emerging threat landscape.



The role and responsibility of the CISO is as below (not exhaustive):

- a. Articulating Information Security Policy for the Organisation ensuring adherence to the policy.
- b. Implement appropriate controls (including policies that PFL uses to protect its information assets apart from coordinating information/ cyber security related issues within PFL as well as with relevant external agencies) and processes to build and protect the organisation from all Information and Cyber related threats, drive cyber security strategy.
- c. Support departments and functions in actively implementing security controls and processes.
- d. Provide assurance, guidance, and advice to senior management on the Information and Cyber threat landscape.
- e. Ensure compliance to extant Regulatory, statutory, and legal requirements on information/ cyber security.
- f. Build and lead the information security team with appropriate competencies and attitude to deliver the information & cyber security program.
- g. Promote user awareness initiatives within the organization.
- h. shall manage and monitor Security Operations Centre (SOC) and drive cyber security related projects.
- i. shall ensure effective functioning of the security solutions deployed.
- j. shall place a review of cyber security risks/ arrangements/ preparedness of PFL before the Board/ RMCB/ ITSC at least on a quarterly basis, as may be applicable.

1.10 Responsibilities of Information Security Team.

- a. Develop and maintain Information Security policy, standards, procedures, and guidelines to support the organizations' information security program.
- b. Translate the information security program into specific actions which shall include effective technical and process controls, awareness, security incident response and risk management.
- c. Work closely with IT and other functional teams and monitor implementation of information security projects and controls.
- d. Identify current and potential legal and regulatory issues affecting information security and assess their impact in conjunction with legal and compliance team.
- e. Act as consultants and advisors to different stakeholders for information security matters.
- f. Perform information security risk assessments on an ongoing basis and report any significant risks to CISO/ ITSC.
- g. Monitor information security incident management i.e., identification, response, remediation and reporting.

1.11 Responsibilities of Information Asset Owner

- a. Information asset owners and / or custodians shall be responsible for the information security of the information/information assets.
- b. Hold the primary responsibility for defining the value and classification of assets within their control.
- c. Be responsible for authorizing appropriate roles and access rights for users and groups including Third parties to the information they own.



- d. Ensure that appropriate access of administration roles or teams exist for their applications to administer access in accordance with the Information Security Policy.
- e. Ensure implementation and compliance to Information Security Policies as applicable for their business units.
- f. Be primarily responsible for risk, data security and access of Third-party partners and vendors to whom line of business has been outsourced.
- g. Review assessment of Third parties at defined frequency to whom line of business has been outsourced.
- h. Ensure Information Security requirements for third parties are implemented and complied as per this policy.

1.12 Responsibilities of Application Owner

- a. Prioritizing any changes to be made to the application and authorizing the changes.
- b. Deciding on data classification/de-classification and archival/purging procedures for the data pertaining to an application as per relevant policies/regulatory/statutory requirements in agreement with business owners.
- c. Ensuring that adequate controls are built into the application through active involvement in the application design, development, and testing and change process.
- d. Ensuring that the Change Management process is followed for any changes in the application.
- e. Ensuring that the application meets the business/functional needs of the users.
- f. Ensuring that the security of the application has been reviewed.
- g. Informing the information security team regarding purchase of an application and assessing the application based on the security policy requirements.
- h. Ensuring that logs or audit trails as required are enabled for the critical applications.
- i. Ensuring User access management process is diligently implemented and complied.

1.13 Confidentiality Agreements

- a. All users, including but not limited to PFL employees, contractors and third-party personnel shall agree to and adhere to the confidentiality agreements.
- b. Whenever communication/interaction with third parties necessitates the controlled release of PFL's sensitive information; a standard Non-Disclosure Agreement (NDA) or a confidentiality clause authorized by PFL's Corporate Legal department shall be signed with the third party prior to the release of the information.

1.14 Contact with Authorities

- a. Contact with the regulators, government authorities/nodal agencies (law enforcement, telecom regulatory authority, fire department, supervisory authorities etc.) shall be established as per the pre-defined procedures.
- b. An updated list of the government authorities/nodal agencies with their contact details (at minimum to include name, mobile number and landline/desk number, emergency contact number) shall be maintained by the Facilities Management.

1.15 Contact with Special Interest Groups



- a. The Information Security team shall maintain appropriate contact with special interest groups and industry known information security forums for receiving and distributing the updates on new vulnerabilities, security threats, regulations and/or risks pertaining to the financial services industry.

1.16 External Parties

Objective: To maintain the security of the organisation's information and information processing facilities that are accessed, processed, communicated to, or managed by external parties.

1.16.1 Identification of Risks Related to External Parties

- a. The risks associated with access to PFL's information systems & applications, by third parties shall be assessed on an ongoing basis.
- b. Based on the outcome of continuous risk assessment, appropriate controls shall be implemented.

1.16.2 Addressing Security in Third Party Agreements

- a. The information security requirements of outsourcing the management and control of all or some of the PFL's information systems, applications, equipment, and network devices shall be addressed in a contract agreed between the third party and PFL.
- b. All third parties shall adhere to PFL's Information Security Policy.
- c. Applicable clauses pertaining to information security shall be identified by PFL and incorporated into the legal agreements while outsourcing any service/work to a third party.
- d. Third parties shall not outsource any work to subcontractors. If there is a business need, the requirement shall be approved through a valid business case and all liabilities applicable to the third party shall apply to the subcontractors. PFL reserves similar rights (viz., audit) with the subcontractor as those with the third party. The third party shall be responsible to enforce PFL's Information Security Policy on its sub-contractors.
- e. Service levels and information security metrics as defined in the agreements shall be monitored and reported by third parties.
- f. Third parties shall be subject to independent reviews on a periodic basis for their compliance with PFL's Third Party Information Security requirements.
- g. Information Security Team along with Business Owner/Application owner shall ensure relevant training updates, DO's /Don't are communicated to Vendors.
- h. PFL shall have the right to continuously monitor and assess the service provider/vendor and its infrastructure, so that deficiencies, if any can be identified and necessary corrective measure can be taken immediately.
- i. PFL shall have the right to access all books, records and information relevant to the outsourced activity.
- j. PFL shall have the right to conduct audits on the service provider/vendor whether by its internal or external auditors, or by external specialists appointed to act on its behalf and to obtain copies of any audit or review reports and findings made on the service provider in conjunction with the services performed for PFL.
- k. Right for PFL or the regulator governing of PFL (e.g., RBI, SEBI) to audit the service provider or their sub-contractor to ensure compliance to contract and prevailing regulations/legislations.



- l. Getting Information security assurance on the information systems that store, process, or transmit organizational information.
- m. Self-Validation or self-declaration from vendor end on security parameters compliance.
- n. Safeguards organization interest and ensures risks are identified prior to vendor onboarding.
- o. Provides continuous assurance on information security controls for onboarded vendors.
- p. Evaluation of potential legal, compliance and regulatory risks with respect to information security/ data security controls.
- q. Identification of high-risk vendors holding sensitive or personally identifiable information of PFL customers.

1.16.3 Addressing Security When Dealing with Customers

- a. The information security requirements related to customers accessing PFL's information/information assets shall be identified by the relevant functional units, along with the Information Security team.
- b. The justification, requirements and benefits for customer access shall be evaluated to ensure the implementation of controls and safety of the organisational assets. The following factors shall be addressed prior to granting access to the customers:
 - The level of access required for the customers and the list of users requiring access.
 - The contractual rights to monitor and revoke any activity related to PFL's information/information assets.
 - Respective liabilities of PFL and the customer.
 - The above-mentioned requirements shall be documented and signed by the customer and PFL. These requirements shall be incorporated in the contractual agreement with the customer.

2 Acceptable Usage Policy

Overview:

The guidelines outline the acceptable use of technology resources at PFL. These guidelines are intended to protect technology resources from various Information & Cyber threats. The guidelines define prohibitive activities for users including but not limited to employees, contractors and third-party personnel (hereinafter referred to as "users") that, if performed, can have serious consequences such as exposure to risks, compromise of information/information assets, information systems, applications, equipment and network devices, legal issues and may lead to a disciplinary action against the user.

Description

2.1 General Use

Objective: To define the acceptable use of the following at PFL:

- Intellectual Property
- E-Mail
- Internet



- Chat rooms, Social Networking and Instant Messaging
- Remote access
- File servers
- Printers
- Software
- Systems and Network

2.2 Securing Proprietary Information

The following guidelines shall be adhered to in order to secure proprietary information at PFL:

- a. Users shall have no proprietary rights or interest in any idea, invention, design, technical or business innovation, computer program and related documentation, or work product (hereinafter referred to as “intellectual property”) developed by the user for PFL.
- b. Users shall acknowledge that all intellectual property developed or used during employment is a property of PFL.
- c. Any unauthorised distribution of proprietary or classified information including shall be prohibited and shall result in disciplinary action against the user.
- d. On termination of employment/contract, the information assets under user’s possession or under the user’s control that may contain sensitive information shall be returned to PFL.

2.3 E-mail Usage

E-mail is a widely used medium for exchange of information between two or more individuals and for business communication; hence the usage of the e-mail shall be governed by PFL. The following sections provide guidelines to ensure that emails are used as an efficient mode of business communication and that the email services are not misused by the users.

- a. All messages generated by the e-mail system shall be considered the property of PFL.
- b. PFL reserves the right to monitor email use to ensure compliance with PFL’s Acceptable Usage Guidelines.
- c. The e-mail system shall be used for business purposes only. However, limited personal use of the e-mail systems may be allowed as long as it does not damage the information and/or reputation of PFL.
- d. The users shall not open attachments received from unknown senders, which may contain malware such as viruses, worms or Trojans.
- e. Transmitting any material that potentially contains viruses, Trojan horses, e-mail bombs or any other harmful or malicious program.
- f. Defaming, abusing, harassing, stalking, threatening or violating any legal and privacy laws.
- g. Forwarding official e-mails to personal e-mail accounts such as Gmail, Yahoo mail and Hotmail. Business related e-mails shall not be sent from a private e-mail account.
- h. Using e-mail in connection with non-business related surveys and contests, chain letters, junk e-mail, spamming, or unsolicited messages is prohibited.



- i. Sending mails to distribution list unless authorised.
- j. Do not send or forward any messages through PFL information systems that contain copyrighted content that is not the intellectual property of PFL.
- k. Do not use PFL information systems for the transmission of any type of unsolicited bulk electronic mail advertisements or commercial messages that are likely to trigger complaints from the recipients.

2.4 Internet Usage

- a. Access to the Internet shall be granted for business-related purposes only.
- b. PFL shall reserve the right to record and monitor internet usage. Any inappropriate use of the internet may result in a disciplinary action.
- c. The downloading of software onto PFL's system without approval is prohibited.
- d. Downloaded software may only be used under the terms of its license agreement.
- e. In case the information from the Internet is used for PFL business decisions, the integrity and the source of the information shall be verified. Additionally, care shall be taken not to violate any copyright laws when using information obtained from the Internet.
- f. Personal use of internet may be limited as long as it does not adversely affect PFL's activities. Users shall not post any derogatory or abusive content on the Internet as official communication from PFL.
- g. No official communication/ response from PFL shall be posted on the Internet unless it has been approved by appropriate authority.

2.5 Remote Access Usage

- a. The remote access shall be provided to the users based on approval and shall be limited to authorize personnel and for business related purposes.
- b. PFL reserves the right to refuse to extend remote access privileges to any user and may refuse or terminate remote access arrangement at any time.
- c. Special care shall be taken while using mobile computing devices to ensure that the organisational information stored thereon is not compromised.
- d. All hosts that are connected to the company's internal networks via remote access technologies must use the most up-to-date anti-virus software.
- e. Authorized Users shall protect their login and password.
- f. All remote access shall be reviewed at periodic intervals.

2.6 File Servers Usage

- a. The access to the file servers shall be restricted to authorised personnel only. Appropriate role-based access rights shall be configured.
- b. Only business-related data shall be stored on file servers.
- c. No personal data would be stored on file servers.



2.7 Printers Usage

- a. Printing of personal items such as photos and personal e-books shall be prohibited.
- b. Printed hard copies of sensitive information shall be protected and destroyed after use as per the Media Disposal Guidelines.
- c. It must be ensured that documents printed on the printer are collected immediately and not left on the printer.

2.8 Software Usage

- a. PFL provides users workstations or other mobile computing devices. All software required to maintain and to keep track of the workstations and mobile computing devices are installed on these devices and shall not be tampered with.
- b. PFL shall not support any non-standard system configurations and shall reserve the right to remove such systems from the network if it poses a security risk to PFL.
- c. Installation of any unauthorised or unlicensed software on the workstations shall be prohibited.
- d. Commercial software purchased by PFL shall be authorised for PFL use only and shall be utilised in accordance with contractual agreements and copyright laws.
- e. Making copies of copyright protected software and related documentation for personal use shall be prohibited, unless specifically authorised within the license agreement.
- f. PFL reserves the right to remove all unauthorised software and the personnel using such software shall be subject to disciplinary action.

2.9 External Storage Devices

- a. Connecting any external storage device is not permitted. By default, access is restricted.
- b. Any external device /portable usage devices must be approved by Department Head and Information security department before same is connected to PFL Network.

2.10 Prohibitive System and Network Activities

- a. The introduction of malicious programs into the network or server (e.g., viruses, worms, Trojan horses, e-mail bombs).
- b. Usage of PFL information/information assets to engage in procuring or transmitting material that is in violation of sexual harassment or hostile workplace laws in the local jurisdiction.
- c. Making fraudulent offers of products, items, or services originating from any PFL account.
- d. Creating security breaches or disruptions in PFL's network communication. The security breaches include, but shall be not limited to, the following:
 - Accessing information to which the user is not an intended recipient.
 - Logging into a server or account that the user is not authorised to access, unless these duties are within the scope of the job function.
 - Disruption includes but is not limited to, network sniffing, pinged floods, packet spoofing, denial of service and forged routing information for malicious purposes.



- e. Network monitoring, which intercepts data not intended for the employee's host, unless this activity is a part of the normal job function.
- f. Providing information about or lists of PFL employees or customers to parties outside PFL when not authorized to do so.

2.11 Incident Reporting

- a. It is the responsibility of all users to report any information security incident they observe or suspect to the IT Helpdesk or Information Security department.

3 Access Control

Overview:

The Access Control Policy defines the controls that need to be implemented and maintained to protect information assets against unauthorised access that poses substantial risk to the organisation.

Unauthorised access to PFL information, impacting confidentiality and integrity of such information can lead to loss of reputation/regulatory non-compliance. In order to mitigate such risk PFL shall follow a uniform process for access control.

Access to information /information assets, information processing facilities, systems, applications equipment and network devices shall be restricted as per the valid business requirements, user's job responsibility and information security requirements. Formal procedures shall be in place to control the allocation of access rights.

Users shall be made aware of their responsibilities for maintaining effective access controls, particularly regarding the use of passwords and the security of user equipment.

3.1 Business Requirement for Access

Objective: To control access to information and information assets.

- a. Except for the publicly held information/publicly available information assets, access to all other information/information assets, systems, applications, equipment and network devices shall be granted based on the legitimate business needs on the Need to Know and the Need to Have basis and after the requisite approval from Department head and Information Security department is obtained.
- b. All information systems, applications, equipment and network devices shall use a centralised authentication mechanism to authenticate users. In absence of the centralised authentication mechanism, a local authentication system shall be used as a primary mechanism to authenticate users.
- c. User IDs shall be linked to specific individuals.



- d. All the users (employees, contractors and third-party personnel) shall be responsible for the activities carried out using their user IDs and password and any other authentication mechanism. If user suspects any malicious activity, password shall be changed immediately.
- e. Access to critical information shall be controlled, based on the business and security requirements and commensurate with the applicable local laws and regulations.
- f. Access to AI models, training data, and inference APIs must be restricted based on the principle of least privilege.

3.1.1 User Access Management

Objective: To ensure authorised user access and to prevent unauthorised access to information systems.

3.1.2 User Registration

- a. Except for the publicly held information/publicly available information assets, the allocation of access rights to all other information/information assets, systems, applications, equipment, network devices and services shall be done in accordance with the User Access Management Process. The process shall encompass all stages in the life cycle of user access, from the initial registration of new users to the final de-registration of users who no longer require access to information systems, applications and equipment.
- b. Every user shall be provided with login credential (a single unique user ID and password) to access PFL's information/information assets, information systems, applications, equipment and network devices.
- c. All user IDs on information/information assets, information systems, applications, equipment and network devices shall be created as per standard and identifiable nomenclature.
- d. Unique system user IDs shall be created. Use of Generic IDs for the purpose of interactive login shall be discouraged wherever possible and any exception to the process will be approved by CTO/CIO.
- e. Every system where a user ID is created, modified and deleted shall have the capability to generate an audit trail of these events. This audit trail shall follow PFL audit logging requirements.
- f. Formal Approval process shall be followed for providing access to all employees, contractors and third-party personnel. This access shall be used for legitimate business purposes and shall be removed when no longer necessary.
- g. All information/information assets, information systems, applications, equipment and network devices shall be configured with strong and effective password management controls.
- h. Accounts that access Restricted or Confidential data shall be reviewed semi-annually, using a documented business process. The review process shall verify that an on-going process is in place to ensure that employees who have left Organisation no longer have active accounts, and those unnecessary entitlements have been removed when roles have changed.
 - For the transferred users (changes in job responsibilities, functional units, PFL legal entities, functions/and or geography within PFL), the existing user access rights shall be revoked and provided access as per the new role, basis formal approval.



- During quarterly user access review, user IDs (on-roll and off-role) shall be disabled in case of inactivity for a period of over at least 30 days. This may vary depending on the need and may vary for different applications or systems.
- User IDs shall be disabled at the end of LWD / end of contract.
- User IDs shall be deleted after 180 days of inactivity or after deactivation post LWD.
- Personnel with elevated system access entitlements shall be closely supervised with all their systems activities logged and periodically reviewed.

3.1.3 Emergency access

- a. Emergency access shall be provided depending upon the type of event and urgency; and will be provided based on approval.

3.1.4 Role based Access Control

- a. Managers are accountable for the access rights of the users under their supervision.
- b. Users shall be granted with least privilege required for a particular role or function.
- c. Additional restrictions shall be implemented for Special Privilege Accounts
- d. PFL employees or third parties that need access to information systems and/or resources to perform their job role shall be granted appropriate access on need basis post head of department's approval.
- e. To avoid dependencies on single or few persons for particular job access to information shall be well defined and segregated.
- f. There should be clear delegation of authority for right to upgrade/change user profiles and permissions and key business parameters (eg. interest rates) which should be documented.
- g. Roles shall be defined in application, based on which users are assigned the particular role. Employees are added in group based on their roles and responsibility.
- h. For financial transactions concept of maker-checker should be followed. Few people should be granted the access to perform the transaction whereas few people should be given access to check each transaction.

3.1.5 Privilege Management

Creation and allocation of privileged user accounts / IDs on the information systems shall be authorized. The procedure shall ensure the following:

- a. The privilege associated with each system (e.g., Operating Systems, Databases, and Applications) and their corresponding users shall be identified.
- b. Privileges shall be allocated to individuals on a 'need-to-have' basis in strict adherence to the authorization process for privilege access; and
- c. A record of all privilege accounts used on the information systems shall be maintained; Changes made to privileged accounts shall be recorded.
- d. PFL shall adopt multi-factor authentication for privileged users for critical information systems.

3.1.6 Personnel Security

The purpose of Personnel Security is to reduce the risks of human error, theft, fraud or misuse of facilities.

3.1.6.0 Prior employment.

a Screening

- Human Resources team is responsible for setting the business' policies and procedures regarding employment screening and/or background checks. Background checks shall be following the local laws and regulations where applicable.
- Where a job, either on initial appointment or on promotion, involves the person having access to sensitive information e.g., financial information or highly restricted information, additional security checks shall be carried out as required.

b Terms and Conditions of employment.

- The security roles and responsibilities of employees are defined and documented in the 'Terms and Conditions of Employment'. Security roles and responsibilities, as laid down in this Information Security Policy shall be documented where appropriate. They shall include any general responsibilities for implementing or maintaining security policy as well as any specific responsibilities for the protection of particular assets or for the execution of particular security processes or activities.
- The security roles & responsibilities shall be defined in consultation with Information Security and Legal teams.
- The roles and responsibilities address general responsibilities related to Information security, legal responsibilities, rights of the employee, specific responsibilities for the protection of assets or for the execution of particular security processes and obligations on completion of employment.
- 'Employees' responsibilities for maintaining confidentiality of information belonging to Organisation during and after employment shall be specifically mentioned in the responsibilities.
- The security roles and responsibilities shall be clearly communicated to every new employee during the induction process and through sessions whenever there is any change in the policy.
- All employees shall sign a confidentiality letter or a non-disclosure agreement which is appropriate to as part of their initial terms and conditions of employment, and the document is to be kept with the employee's HR file.



The HR function shall ensure that the 'Terms and Conditions of Employment' reflect the Information security requirements and include the following:

- The requirement for all employees to sign a confidentiality agreement which shall hold them liable for any unauthorized disclosure, modification and/ or destruction of information.
- The responsibility for maintaining the confidentiality and integrity of information.
- The actions to be taken if any user disregards the requirements of the Organization Security Framework.
- The continuation of the employee's responsibilities for protecting the confidentiality of the information of organization even after termination of employment.

3.1.6.1. During Employment

Management shall prepare a security manual that lists the Organization's security policies and procedures. All personnel shall be required to provide written or electronic acknowledgment that they have received, read, and understood the security policies and procedures. The Management, or the information resources manager acting on delegated authority, shall determine how often this written acknowledgment shall be renewed.

All employees shall be required to do the following:

- Sign the Terms and Conditions at the time of joining the organization.
- Mandatory Information Security team training shall be done by all the employees on a yearly basis.

Organization employees shall accept and acknowledge their information security responsibilities.

a. Information Security Awareness, Education and Training

The purpose of user training is to ensure that users are aware of information security threats and concerns and are equipped to support organizational security policy in the course of their normal work.

Organization shall have and maintain an Information Security Awareness Program. All employees would be made aware of information security requirements through mailers, online sessions, using bulletin boards, newsletters, and posters to focus attention on the importance of information security, incorporating security awareness in the performance rating process.

Site Information Security leaders shall be nominated (by site / branch head) for every site / branch and shall be trained on Information Security requirements. In addition to that, posters / templated procedures for security awareness of customers shall be displayed in all Organization offices / branches.

b. Disciplinary Process



Certain categories of activities, which have the potential to harm information assets are defined as security violations and are strictly prohibited. Such security violations shall result in disciplinary process.

3.1.6.2. Termination and change of employment

Managers / HR shall submit an off-boarding request through email/ workflow in the event of an employee termination/retirement/resignation.

Physical building access, application access and remote access rights etc. shall be disabled for all terminated staff member within 24 hours of termination.

Managers / HR are responsible for ensuring that Organization employees return Organization assets in their possession at the termination of their employment or contract in accordance with Organization policies & procedure and local laws & regulations.

Managers / HR are responsible for ensuring revoking of access to employees whose roles have changed or are transferred.

It's the responsibility of managers to ensure new access levels recommended as per the job profile of the employee. Managers shall ensure the access levels are verified and monitored at regular intervals.

Note: All access shall be revoked on the last working day of the employee/contractor/third party staff.

3.2 User Responsibilities

Objective: To prevent unauthorised user access, and compromise or theft of information and information processing facilities.

3.2.1 Password Use

- a. For all information systems, applications, equipment and network devices, any system generated password provided to the users shall be changed after the first login.
- b. Passwords shall never be shared or revealed to anyone other than the authorized user.
- c. Users shall minimize the use of fixed passwords in any computer files, such as logon scripts or computer programs,
- d. Users shall keep their user IDs and corresponding passwords confidential and refrain from sharing them with others.
- e. All PFL information systems, applications, equipment and network devices shall be configured to ensure that passwords typed are masked, suppressed or otherwise obscured such that unauthorized parties may not be able to observe and/or subsequently recover them.
- f. Passwords shall not be written down or stored in clear text.
- g. Users shall ensure that the passwords are kept confidential and shall not be shared or disclosed to anyone including the IT Help Desk.
- h. If a temporary password has been provided to the user, it shall be changed immediately upon the next logon. (It should be the part of System requirement rather than User Responsibility).



- i. Password age for service accounts shall be maximum of 180 days.

Password Parameters

- a. PFL shall use strong passwords and/or pin/token to protect access to PFL information and information processing facilities to minimize the risk of unauthorized access.
- b. Passwords should necessarily satisfy following complexity criteria:
 - i. Passwords shall be of minimum 8 characters and should contain combination of upper case and lowercase letters, numerals and special characters.
 - ii. Passwords should not be based on entities that can be easily guessed or obtained using personal information such as names, telephone numbers, date of birth, words commonly found in dictionary, company names etc.
 - iii. Passwords shall be changed after a predefined 60 days' period.
 - iv. Minimum password age should be minimum 1 day.
 - v. Password history of at least 5 passwords shall be maintained.
 - vi. The number of unsuccessful logon attempts shall be limited to 5, post which account shall be locked out.

3.2.2 Unattended User Equipment

- a. All PFL provided information systems, applications, equipment and network devices to PFL employees, contractors and third-party personnel shall not be left unattended.
- b. All information systems, applications, equipment and network devices shall be configured with a screen-lock out in case of inactivity for at least 10 mins or as per agreed pre-defined period.
- c. Users shall terminate / log-off from all active sessions on information systems/applications, equipment and network devices when their activity is complete or leave their desks for an extended period of time.

3.2.3 Clear Desk and Clear Screen Policy

- a. A clear desk policy for papers and a clear screen policy for information processing facilities shall be adopted in order to reduce the risks of unauthorised access, loss of and damage to information during and outside normal working hours.
- b. It is the responsibility of all employees and third-party staff to adhere to the below mentioned requirements:
 - Where appropriate, paper and physical media shall be stored in suitable locked cabinets and/or other forms of secure closets when not in use, especially outside working hours.
 - Outside of regular working hours, all employees shall clear their desks and working areas of all sensitive or valuable information.

3.2.4 Secure Log-on Procedures

- a. The access to the operating systems of information systems, equipment and network devices shall be restricted through a defined log-on procedure and access controls.
- b. The log-on procedure shall ensure that
 - A message/banner shall be configured wherever possible to warn users that unauthorised use is prohibited, and that legal action shall be taken against offenders.
 - The system shall not disclose any system related information unless the user is authenticated.
 - Direct root/super user/administrator login shall be disabled wherever possible or restricted to be used on certain occasions which shall be authorized by appropriate authority.
 - All the operating system/applications shall be configured to log in users with unique user IDs.
 - A secure login shall ensure that, if it is a remote login, it shall be through a secure protocol (SSH, HTTPS).
- c. The number of unsuccessful logon attempts shall be limited to 5, post which account shall be locked out.

3.3 Mobility & Remote Computing

Objective: To ensure security controls and processes are as effective when work from home (WFH) is provided to users during a prolonged disaster or crisis situation.

- a. Employees having company provided/ owned assets shall be authorized to connect remotely to the network and access internal applications / data.
- b. All required security controls on company provided assets shall be implemented and managed to always ensure effectiveness.
- c. Employees using BYOD shall not be provided direct access to the network. They may continue to access Web facing & Cloud applications accessible on the Internet.
- d. Data download restrictions or similar controls shall be implemented for users using BYOD devices.
- e. Users, on their part shall be responsible and take appropriate measures to ensure that their personal devices are always secured; by using Anti-virus, patch updates, genuine software, etc. (For more information, refer to the BYOD policy).
- f. Users shall take appropriate steps to prevent any type of compromise or breach of company information residing on their devices.
- g. The same level of access privileges shall be provided when user connects from outside the network.
- h. Authorized access to network, applications or data shall be provided post successful identification and authentication of the user and their authorized device.
- i. Encryption shall be mandatory for all laptops (including Third Party users), subject to laws and legal restrictions.
- j. The technology used for mobile services by Organisation shall ensure confidentiality, integrity, availability, and authenticity and shall provide for end-to end encryption.

3.4 Logging and Monitoring

Objective: To detect unauthorized information processing activities



- a. Logging shall be enabled on all critical information assets including application servers, network devices, operating system, database, web servers and security devices.
- b. The extent of audit logging shall depend on the business criticality of the information system and the data handled by the system.
- c. The systems shall log the following wherever possible:
 - Unique user identifier such as user ID.
 - Source IP address of the user's computer.
 - Date and time of action.
 - Type of action performed; and
- d. It shall be ensured that the system administrators do not have permissions to access, erase or disable logs.
- e. All critical information systems shall have facility to store logs as per the local laws and regulatory requirements.
- f. Audit logs may be archived. The system used for archiving the audit logs shall have the same level of security as that of the source information system. The level of security shall be based on the classification of the information asset from which data is being obtained.

3.4.1 Monitoring System Use

- a. PFL shall establish a centralized Security Operations Centre (SOC) to monitor all intrusions, attacks, alerts, review of the security logs and incidents.
- b. All critical PFL information systems, applications, equipment and network devices shall be monitored on a continuous basis (24x7x365)
- c. PFL shall deploy a log monitoring and correlation mechanism to address and adhere to the audit logging and monitoring requirements described in this policy.

3.4.2 Protection of Log Information

- a. Log information shall be protected against unauthorized access, alterations and operational problems. Access to logs shall be provided on 'need-to-know' and 'need-to-have' basis.
- b. Audit logging settings shall be configured in such a way that the audit logs cannot be disabled or overwritten.
- c. Any changes to the audit logging configurations and parameter settings shall follow the Change Management Procedures.
- d. System Audit logs shall be retained for the period of at least 90 days.

3.4.3 Administrator and Operator Logs

- a. All information systems, irrespective of the business criticality and the data handled, shall be configured in such a way that the system administrator and system operator activities are logged.
- b. It shall be ensured that the system administrators and system operators do not have permissions to erase or deactivate logs of their own activities. All information systems shall have the capability to record, at a minimum the following wherever possible:
 - Login failures

- Account lockouts
- System boot and restart time
- System or application start, stop, re-initialization (with user identity and time of action)
- System configuration changes
- System errors and corrective actions taken
- Production applications start and stop times.

3.4.4 Fault Logging

- a. Fault logging shall be enabled for all the information systems, equipment and network devices.
- b. Fault logs may be reviewed on the regular basis to ensure that all the incidents are reported, investigated, and resolved in a timely manner.
- c. The problem management procedure shall have the mechanism to record information security related problems, reduce their incidence, and to prevent their recurrence.

3.4.5 Clock Synchronization

- a. All PFL information systems shall have national/regional time defined, the correct interpretation of the standard date/time format shall be ensured. The format shall be identical across all servers and network devices.
- b. All PFL information systems shall support time synchronization and must be maintained via Network Time Protocol (NTP) and must be configured to retrieve time from an authoritative and trusted time source.

4 Cryptography

4.1 Policy on the use of Cryptographic controls

- a. Organisation understands the importance of information either in transit or stored and hence strives to protect it via cryptographic keys & certificate management wherever feasible and appropriate. The level of protection applied shall be commensurate with the sensitivity and frequency of use of the information along with the environment where it resides/used.
- b. Key custodians shall be made aware, and they shall formally acknowledge their obligations in administering the security of the keys.
- c. PFL shall use only internationally accepted and published cryptographic standards or protocols (such as AES-256, SHA-2, TLS-1.2/1.3 etc.) that are not deprecated/ demonstrated to be insecure/ vulnerable. The configurations involved in implementing such controls shall be compliant with extant laws and applicable regulatory instructions.

5 Information System Acquisition, Development and Maintenance.

Overview:



Based on business need, requestor (management or business users) shall submit their requirements on a predefined template, based on their understanding of their functionality need, to the IT department.

Respective department heads shall evaluate this proposal after performing a feasibility study. This study shall include:

- Current deficiencies.
- Expected benefits.
- Functional requirements to be provided by the software.
- Alternate off-the-shelf products and solutions available in the market; and
- Estimated cost in terms of manpower required and other software / hardware required for developing the solution.
- Project managers and other department heads shall keep in loop information security team to ensure security & compliance of the proposal.
- The feasibility study report shall be analysed in terms of cost & benefit and any of the following decisions may be made.
- Develop the product (in-house or outsourced).
- Buy a Commercial Off-The-Shelf (COTS) product.
- Buy the product and customize; or
- Reject the request.
- Project managers and department heads shall also assess the interoperability of the proposed solution with the existing application & environment.

5.1 Security Requirements of Information Systems

Objective: To ensure that security is an integral part of information systems.

5.1.1 Security Requirements Analysis and Specification

- a. All the relevant functional units shall ensure that information security requirements are established for the following:
 - Initiating any new projects.
 - Developing/acquiring new systems or services.
 - Carrying out/facilitating enhancements to systems/services.
 - Procuring new software products and services and deployment of new information technology, initiatives
- b. Business requirements for new systems or enhancements to existing systems shall specify the required information security controls.



- c. A formal SDLC shall be adopted and applied for all development efforts. The design of all systems, and applications, especially those systems with high confidentiality or availability requirements, shall include security assessment and risk reduction as major design objectives. Any information system modification (enhancement, modification, and upgrade) shall include updates to the initial design and security documents to reflect changes.
- d. The production, development / test environments shall be segregated. The production environment shall be physically segregated from the development and testing environment.
- e. If the production data is required for testing and development activities, production data shall be sanitized and masked prior to its use in the test or development environments.
- f. Controls, as per applicable laws and regulations and PFL policy and procedures shall be integrated during acquisition, development, deployment and maintenance of the information systems application software, system software, products and/or services.
- g. For the customized software developed by a third party, arrangements pertaining to license, code ownership and intellectual property rights shall be documented in the contract between PFL and the third party. The contract shall have escrow arrangements.
- h. The licensing arrangements shall consider the local laws and regulations while complying with the enterprise level license requirements.
- i. All new applications/products shall be formally reviewed for compliance with the IS Policy and a sign-off on the same shall be obtained from the Information Security department before deploying in the production environment.

5.2 Security of System Files

Objective: To ensure the security of system files.

5.2.1 Control of Operational Software

- a. All security fixes provided by software vendors and identified for implementation shall go through the Change Management Procedures.
- b. Users requiring software not published in the standard software list shall request for such software only after receiving the requisite approval from the relevant Functional Head and the Information Security department.
- c. Unauthorised software including freeware and demo copies of software shall not be installed. Should there be a need; the software shall be installed only after the approval from the relevant Functional Head and the Information Security department.
- d. Access to the installed software on operational/production information systems application software, system software, products shall be restricted to the authorised personnel only.
- e. Modifications to the operational/production environment shall be logged and previous versions shall be maintained for contingency/roll back purpose.

- f. New executable code shall be implemented in the operational/production environment only after successful completion of testing and user acceptance of the system in a separate controlled environment, and the Change Management Procedures shall be followed.
- g. Vendor supplied software packages shall be maintained at the level that is supported by the vendor.
- h. All upgrades and applications of service packs shall be carried out after appropriate testing and evaluating the additional information security measures provided by the vendor. In case of any exceptions due to technical limitations, approvals shall be taken from the relevant Functional Head and Information Security department.

5.2.2 Protection of System Test Data

- a. Access provided to production business information for the purpose of extracting data required for testing, shall be “read” and “copy” only. The access on the production system/environment shall be approved and be granted by the Functional Head and the Information Security department only for the duration of the testing and related development efforts. The access shall be promptly revoked upon the successful completion of these efforts.
- b. Acceptance tests shall be carried out using the test data, which shall be similar to the operational/production data and shall be masked.
- c. The software development team shall ensure that dummy data is secured and sanitised during testing. Separate authorisations shall be required every time the operational data is used for testing purposes.

5.2.3 Access Control to Program Source Code for Applications Developed in-house

- a. All production program source code shall be stored in a software version management database.
- b. A software version management database shall maintain the version control of all programs and change control procedures that need to be followed for any modifications to the program source library.
- c. Access to the production data, production programs, or the operating system shall be restricted to the authorised personnel on the need to have and need to know basis.
- d. Access to the program source shall be restricted to prevent any corruption of the application programs.

5.3 Security in Development and Support Processes

Objective: To maintain the security of application system software and information.

5.3.1 Change Control Procedures

- a. Changes to the application systems shall be carried out in a controlled manner as per the Change Management Procedures.

5.3.2 Review of the Proposed Design

- a. The proposed design and the project plan will be subjected to a review process by IT and Information Security department, if required.



5.3.3 Testing

- a. All programs will be adequately tested before they are released for use to the business users. This will include all new software as well modifications to the existing software and reports.
- b. IT will invite user feedback in designing test criteria that can be used to measure the success of individual components of the program. The test criteria will be based on the business functionalities and objectives of the program and would provide measurable results.
- c. All new software will be tested for performance and resource utilisation before being released to the business users.
- d. IT will ensure that users are involved in conducting User Acceptance Tests (“UAT”) before the programs are released into the production environment for business use. Users shall sign-off their acceptance of the programs before release.
- e. IT will maintain documentation of all tests conducted on the programs developed by it.

5.3.4 Technical Review of Applications after Operating System Changes

- a. All operating systems shall be periodically updated with the new release or patches from vendors.
- b. New releases/patches pertaining to the operating system shall be tested before being implemented in the production environment to ensure that there is no adverse impact on operation, application controls or security. In case of any exceptions due to technical limitations, approval shall be taken from the Information Security department.

5.3.5 Restrictions on Changes to Software Packages

- a. Prior to being installed, new or different versions of the operating system and related systems software for multi-user production computers shall go through the Change Management Procedures.
- b. Vendor-supplied software packages shall not be modified without consulting the vendor.
- c. Any requirement for change to such software shall undergo the Change Management Procedures. If changes are essential, then original software shall be retained, and changes could be applied to a clearly identified copy.

5.3.6 Outsourced Software Development

- a. Third parties who develop software for PFL shall be bound by a contract with PFL. For the software developed by third parties, arrangements pertaining to licensing, code ownership and intellectual property rights shall be documented in the contract between PFL and the third party.
- b. The contract shall include that PFL reserves the right to audit quality and accuracy of software development and testing. The contracts shall have escrow arrangements.

6 Change Management

Change requests shall be documented, logged and categorized as ‘Standard’, ‘Normal’ or ‘Emergency’.



All changes (including emergency changes) to PFL Information Systems and Information facilities shall be performed in accordance to the 'Change Management Procedure'. Further, for Changes made to Information Systems supporting the processes, applicable procedures as documented shall also be followed.

Note: Please refer to the PFL Change management Policy.

7 Incident Management

Overview:

The primary objective of the Security Incident Management process is to ensure that security events and weaknesses associated with are communicated in a manner allowing timely corrective actions to be taken, restore normal service operations as quickly as possible and minimize the adverse impact on business operations,

The increasing dependency and associated risk of IT environment increases the risk of business disruption. To reduce the impact of disruptions, the organisation shall have a process in place to effectively monitor, detect and resolve security related incidents in a timely manner. In addition, the organisation shall proactively implement controls to reduce the recurrence of such incidents in future.

Formal event reporting and escalation procedures shall be in place. Employees, contractors and third-party personnel shall be required to report any information security events and weaknesses as quickly as possible to the designated point of contact.

Responsibilities and procedures shall be in place to handle incidents and weaknesses effectively once these are reported. A process of continual improvement shall be applied to the response, monitoring, evaluating, and overall management of incidents.

7.1.1 Security Incident Management

Objective: To ensure information security events and weaknesses associated with information systems are communicated in a manner allowing timely corrective action to be taken.

7.1.2 Scope

This process covers any incident, external or internal, which impacts directly or indirectly on the services provided within the agreed Service Level Agreement. All incidents will be recorded on the logging system

- a. All incidents shall be recorded in Poonawalla Service Desk (PSD) and followed up with the respective IT teams for root cause analysis and closure of the incident. Recurring incidents are classified as problems and are analyzed prioritized and solved in a structured manner.
- b. Priority will be allocated to problems, incidents and security threats in particular. High priority problems and incidents will be dealt with immediately and problems will be tracked by suggesting remedial measures.



- c. Follow-up actions will be initiated for the problems and incidents and relevant personnel in-charge of resolving the problems will be notified immediately.
- d. All problems and incidents will be tracked including time taken to resolution, root cause analysis, etc.
- e. The problem and incident management team will maintain comprehensive and up-to-date documentation for all problems and incidents.
- f. Escalation procedures shall be formulated to address emergencies and incidents having major impact on PFL.

7.1.3 Reporting Security Events and Weaknesses

- a. PFL shall establish Information Security Incident Response Procedures for reporting any suspected security incidents (security weaknesses or threats to information systems, premises, or services etc.)
- b. Users will be responsible for reporting any observed (or suspected) security weakness or any other incident immediately to the IS Department/ IT Service Desk and will not share such information with internal or external parties.
- c. Incident reporting and management procedures will be made available for easy access and reference for the purpose of reporting security incidents and weaknesses by the users.

7.1.4 Management of Incidents

Management responsibilities and procedures will be established to ensure a quick, effective and orderly response to security incidents. The security incident management procedures will ensure that:

- a. Types of incidents will be clearly defined and regularly updated:
- b. Analysis and identification of the cause of the incident is undertaken.
- c. Categorization of the incidents based on the severity of the incidents.
 - The criteria to categorize and prioritize incidents shall take into account multiple aspects of impact (e.g., scope, application, service, reputation, environment, etc.), urgency and number of users affected, as shown below:

Priority Level	Description
Priority 1 (High)	HIGH priority incidents have a significant impact on business. These incidents are handled by assessing the situation and responding immediately. For e.g., Loss of customer information.
Priority 2 (Medium)	MEDIUM priority incidents have a moderate impact on business and are handled by responding and operating within the normal supervisory management structures. For e.g., Loss of access card.
Priority 3 (Low)	LOW priority incidents have little or no impact on business. These events are handled with less priority.

- d. Corrective actions are defined based on the category of the incidents

- e. Planning and implementation of corrective action to prevent recurrence is carried out, if necessary
- f. Communication with those who are affected by or are involved in the recovery from the incident is done
- g. Escalation matrix is defined based on the category of the incidents
- h. Reporting the action taken to the appropriate authority
- i. Audit trail and similar evidence are collected and secured
- j. All emergency actions taken are documented in detail, reported to management and reviewed in an orderly manner.

The action plan will include

- Particulars about the business unit or department
- Facts and explanation/ reason for the incident
- Severity of the incident
- Other business units/ departments affected
- Corrective actions to be taken
- Estimated cost of implementing the corrective action (if any)
- Estimated time frame, start date and end date

7.1.5 Learning from Security Incidents

- a. Information security incidents shall be monitored and analysed. The review shall include the following at a minimum:
 - Incident reporting time
 - Reported by
 - Description of the incident
 - Root cause analysis
 - Incident closure time
 - Incident owner
 - Closed by
 - Reason for closure
 - Media Announcement and Crises Management, if required
- b. Incidents with high business impact shall be identified and appropriate controls shall be enhanced to reduce the risk from future occurrences of such incidents.
- c. PFL shall establish a knowledge base for the information gained from the evaluation of all information security incidents. The knowledge base shall be referred to for incident handling and as a learning source of information security incidents.

7.1.6 Collection of Evidence

- a. Formal guidelines will be established to ensure adequate evidence is collected for the investigations involving security incidents.



- b. Guidelines will be defined to assess the admissibility and weight of the evidence based on the applicable laws and published standards.

8 Information Backup and Archival.

Overview:

The objective of this policy is to identify and define guidelines for protecting against loss of important information stored within the information systems of PFL and backup critical data of PFL's business and communication systems and restoring the same.

Description

8.1 Backup

Objective: To maintain the integrity and availability of information and information processing facilities.

8.2 Information Backup

- a. A formal backup SOP shall be documented identifying the information systems and applications information to be backed up, with the type of and frequency of backups.
- b. Information owners shall provide specific backup requirements to IT.
- c. Information backup and restoration procedures shall be established and implemented to ensure the availability of business information.
- d. Backup operators shall store backup logs with appropriate access rights assigned to them. The backup operator shall carry out a log analysis for all failed backup and restorations and take corrective actions, as appropriate.
- d. Frequency of backup and restoration testing shall reflect the business requirements.
- e. Business-critical data shall be duplicated. One copy shall remain onsite and the other stored in a secured off-site location. The backup media shall be kept in a fireproof safe.
- f. Backup operators are responsible for the appropriate rotation of backup media. The rotation schedule and the number of tapes shall be decided on the basis of business requirement of backed up data.
- g. Backup storage location shall have appropriate level of physical and environmental protection consistent with the standards applied at the main site.
- h. Backup media shall be encrypted, depending on the classification of the data stored on it.
- i. Backup media shall be handled in accordance with the classification of the data stored on it and shall be disposed of as per the Media Disposal Guidelines

8.3 Information Backup Testing

- a. Restoration testing shall be conducted for the backed-up data at periodic intervals to check the integrity and adequacy of the backup.
- b. Any discrepancies or errors found during the backup testing shall be reported to the concerned information owner.



- c. The test results shall be documented, and the backup process shall be improved to avoid similar discrepancies in future.
- d. Backup details and frequency details are defined in the backup SOP.

9 Asset Management

Overview:

The Asset Management Policy specifies the importance of information/information assets including identification of the asset owner, asset classification and determining confidentiality, integrity and availability ratings of the assets. The policy establishes the requirement of controls that need to be implemented for protecting information/information assets.

The coverage and scope of the information security initiatives are dependent on how well an organization knows its assets. The risk increases further as loss of an asset might result in disruption in PFL's operations and might also lead to unauthorized disclosure. Therefore, PFL shall maintain a repository to track the allocation and movement of assets and implement security measures based on criticality of the assets.

All information assets shall be accounted for and have a nominated owner. Further, information shall be classified to indicate the need and expected degree of protection when handling the information/information asset.

9.1 Responsibility for Assets

Objective: To achieve and maintain appropriate protection of organizational assets.

9.1.1 Inventory

- a. A detailed inventory shall be maintained for all IT assets and ensure appropriate protection of PFL's information assets.
- b. The IT asset owners shall be responsible for maintaining the current inventory of assets.
- c. The business users shall also maintain an inventory of IT assets owned by their respective departments.

9.1.2 Ownership of Assets

- a. All information assets must have an identified owner who is responsible for defining its classification, determining the appropriate access and use of the information and for managing the asset throughout its lifecycle.
- b. The owner is responsible for the implementation of the required controls for the protection of the assets.

9.1.3 Asset Classes

- a. Based on the Confidentiality, Integrity and Availability requirements, different types of IT assets with different types of merit and levels of protection requires assets classification such as:

1. Critical Assets
2. Non-critical Informational Assets
3. Non-Informational Assets
4. Informational Assets

9.1.4 Physical asset Labelling

- a. Physical IT assets may be appropriately labeled, based on agreed nomenclature.

9.1.5 Acceptable Use of Assets

- a. All employees, contractors and third-party personnel shall be responsible for handling the assets as per the classification of the asset.

9.1.6 Asset Movement

- a. All asset movement - intra-office and inter-office (hardware, media etc.) shall be approved by relevant authority.

9.1.7 Maintenance and Upgrades

- a. Only authorized patches / upgrades received from the respective vendors will be used for the hardware/software assets. All patches/upgrades will be tested before installation to the extent possible/desirable.

9.1.8 Classification of Information Assets

Information assets will be classified into the following categories and marked as such based on their confidentiality requirements and their importance to the Company. Information can be classified as following:

- **Public**

General release information is widely disseminated amongst the public at large and requires the lowest level of security protection. However, reasonable care may need to be taken to maintain its integrity and correctness.

- **Internal**

This information is intended for use within Organisation, and in some cases within affiliated organizations, such as Organisation business partners. Unauthorized disclosure of this information to outsiders may be against laws and regulations, or may cause problems for Organisation, its customers, or its business partners.

- **Restricted**

This information is the most private or otherwise sensitive and shall be strictly monitored and controlled at all times. Unauthorized disclosure of this information to people without a business need for access may be against laws and regulations, or may cause severe problems for Organisation, its customers, or its business partners.

- **Confidential**

Information is classified as strictly confidential only if its disclosure would cause serious damage to the Company or any other party to whom the information pertains.

Strict security and control measures will be adopted to prevent unauthorized access to this type of information. Confidential information requires the highest level of protection and shall be made available only to few authorized personnel of the Company.

9.2 Information Labelling and Handling

- a. All users will identify information assets under their custody and initiate appropriate steps to protect them.
- b. Labels are physical or digital markings that clearly state the classification level of the information/information asset.
- c. The owner or creator of information/information asset shall assign an appropriate label to the information, and the user or the recipient of this information/information asset shall consistently maintain the assigned label.
- d. All the unlabelled information/information assets shall be viewed as “Internal” unless otherwise classified.
- e. Making additional photocopies or printing extra copies of information/information assets classified as “Restricted” or “Confidential” shall not take place without the prior permission of the information owner.

9.3 Protection of Intellectual Property

- a. Necessary measures shall be in place to protect the intellectual property of the Company.
- b. PFL shall assume ownership of all intellectual property (e.g., software, application etc.) developed by outsourced vendors and/or users of information systems during their engagement with / employment in the Company.

9.3.1 Disposal of Assets

- a. All unwanted and obsolete IT assets will be disposed of after approval by the CIO / CTO.
- b. IT will ensure that the assets under its custody are disposed securely.
- c. All data stored on magnetic media is destroyed by low level formatting / degaussing the floppies, tapes, hard disks etc.
- d. Printed material containing sensitive data shall be shredded before disposal.

9.3.2 Periodic Review

- a. The Information Security department may conduct periodic reviews of the Information System asset classification to ensure its adequacy and appropriateness.

10 Compliance Policy

Overview:

The Compliance Policy provides direction towards design and implementation of appropriate controls to comply to local laws, regulations, statutory and contractual requirements at PFL.

The security of information systems shall be regularly reviewed. These reviews shall be performed against the PFL’s IS policies and the technical standards.

Description



10.1 Compliance with Legal Requirements

Objective: To avoid breaches of any law, statutory, regulatory or contractual obligations, and of any security requirements.

- a. The Legal function shall identify the relevant and applicable laws, regulations, statutory and contractual requirements for business operations and intellectual property rights. The laws, regulations and contractual requirements shall be defined explicitly and documented.
- b. Information security aspects specified in any circular or note released by legal and/or regulatory authorities shall be complied with.

10.2 Compliance with Security Policies, Standards and Technical Compliance.

Objective: To ensure compliance of systems with organisational security policies and standards.

10.2.1 Compliance with Security Policies and Standards

- a. Functional Heads shall ensure compliance with the IS Policy at all the times.

10.2.2 Technical Compliance Checking

- a. Periodic reviews and random tests shall be performed on information systems to assess compliance with the IS Policy.
- b. All functions shall obtain a security clearance for activities such as all new projects, products, applications, services, from the Information Security department during their initiation and prior to deployment in the production environment.
- c. The technical compliance checking shall cover penetration testing and vulnerability assessments, which could be carried out internally or by independent experts specifically contracted for this purpose.
- d. In addition to regular reviews, information systems security risk assessments for critical information systems and critical production applications shall be reviewed periodically and all major enhancements, upgrades, conversions, and changes associated with these systems or applications shall be preceded by a risk assessment.

10.2.3 Protection of records

- a. Important records of an organization shall be protected from loss, destruction, unauthorized access, unlawful and unauthorized duplication, tampering and falsification, and in some cases retention of certain records for certain periods of time is required by law. However, it is not possible or desirable to keep everything forever.
- b. Data protection and privacy shall be ensured as required in relevant legislation, regulations, and, if applicable, contractual clauses.
- c. Personal Identifiable Information (PII) or information that can be used on its own or with other information to identify, contact or locate a single person, mentioned in any document or over mail shall be treated as confidential. PII includes - customer name, phone number, Aadhar number, PAN number, credit card details.



Other Potential PII fields could be - bank account information, residential address, pin code, demographic information.

- d. Data Loss Prevention solution shall be implemented in order to protect information from going out of the organization's boundaries undetected, wherever possible.
- e. Relevant legislation, regulation, and contractual clauses for collecting, using and storing PII shall be identified.
- f. The purpose for which PII was collected shall be identified by the owner. Owner shall conduct a self-review against the purpose and report any deviations for which appropriate action shall be taken based on a Root Cause Analysis (RCA).
- g. Access to PII shall be available only to authorized personnel only. This authorization shall be provided by the business function.
- h. PII shall be stored on network drives and/or in application databases with strong access controls measures (for e.g., User IDs/password) and shall be made available only to those individuals with a valid and approved business need.
- i. All incidents involving data breaches which could result in identity theft shall be coordinated by information security team for investigation and closure.
- j. If PII needs to be transmitted over the Internet, it shall be sent using encryption methods.

10.2.4 Privacy and protection of personally identifiable information

The data protection and privacy of (such as customer details, restricted data etc.) against unauthorized access, transmission, publication, damage, use, modification, disclosure and impairment shall be ensured at Organization by implementing adequate technical and administrative control.

10.3 Information Systems Audit Considerations

Objective: To maximize the effectiveness of and to minimize interference to/from the information systems audit process.

To ensure that the Information Security Management System (ISMS) is working effectively, the audit for the information systems shall be performed either by the internal audit team of the organization or by some external auditor for an independent review of the controls that have been implemented.

- Annual audit schedule, audit requirements and scope of audit shall be agreed upon with appropriate representatives of business units involved.
- IS Audit shall cover effectiveness of policy and oversight of IT systems, evaluating adequacy of processes and internal controls, recommend corrective action to address deficiencies and follow-up.
- IS Audit shall also evaluate the effectiveness of business continuity planning, disaster recovery set up and ensure that BCP is effectively implemented in the organization.
- Due importance shall be given to compliance of all the applicable legal and statutory requirements.

- IS Auditors shall act independently of NBFCs' Management both in attitude and appearance. In case of engagement of external professional service providers, independence and accountability issues may be properly addressed.
- Organisation shall refer the IS framework guidance issued by bodies like ISACA, IIA, ICAI.
- Organisation shall adopt an IS Audit framework duly approved by their Board.
- PFL shall have adequately skilled personnel in Audit Committee who can understand the results of the IS Audit.
- PFL shall adopt a proper mix of manual techniques and Computer-Assisted Audit Techniques for conducting IS Audit and carrying it out at least once a year.
- IS audit shall be conducted once in a year based on the size and operations.
- PFL management is responsible for deciding the appropriate action to be taken in response to reported observations and recommendations.
- Wherever access to operational system is required, it shall be limited to read only access to software and data. This access shall be removed when the audit is completed.
- Exceptions to above requirement shall only be allowed for isolated copies (copies of system files that are not linked to the original) of system files, which shall be erased when audit is completed.
- Audit procedures, requirements, responsibilities and findings shall be documented.
- Access to information system audit tools (for e.g., software and data) shall be protected through appropriate controls to prevent any possible misuse or compromise.
- Non-Disclosure Agreement shall be obtained from (external) auditors.

10.3.1 IA Charter

- Information Technology, Information Security & Outsourcing Partners Audit:
- Internal Audit Department needs to ensure the mentioned departments are covered under their audit plan as per the IA Charter. IT, IS & Outsourcing Partners Policy, Process documents would cover this in more detail.
- The Audit report would be presented to Audit Committee of Board-ACB by Internal Audit Head.

10.3.2 Protection of Information Systems Audit Tools

- Appropriate protection shall be provided to system audit tools, i.e., software or information files, in order to prevent any possible misuse or security compromise.
- Access to these tools shall be restricted to select few individuals and only after formal approval. Appropriate protection shall be provided to system audit tools, i.e., software or data files, in order to prevent any possible misuse or security compromise.
- Audit trails and system access reports shall be monitored by the Information Security team.

11 Physical Security

Overview:

Establishing physical and environmental security controls forms a first step towards protecting the work environment and supporting infrastructure to prevent or reduce the impact of incidents resulting in disruption of services and protecting confidential information from physical intrusion/theft.

Information assets shall be physically protected from unauthorised access, misuse, damage and theft. All the PFL premise and facilities shall be adequately protected from physical and environmental threats.

Description

11.1 Secure Areas

Objective: To prevent unauthorised physical access, damage, and interference to the organisation's premises and information.

11.2 Physical Security Perimeter

- a. PFL information processing facilities include, but not limited to; PFL campus, facilities, offices, work areas, secure areas, critical infrastructure rooms (CIR). A CIR includes data centres, server rooms and telecommunication rooms.
- b. Surveillance systems shall be installed to monitor designated entry and exit points at all important facilities.

11.3 Physical Entry Controls

- a. Access to information processing facilities shall be controlled by the use of an access control system.
- b. Access to all PFL campus and information processing facilities shall be approved and restricted to authorised personnel only.
- c. Reception areas shall be manned by a receptionist(s) and/or security guard(s).
- d. All authorised personnel shall be issued a personally identifiable photo badge and the same shall be always displayed. Follow a no-tailgate policy.
- e. All entry/exit points shall be monitored by using an electronic surveillance system on a 24x7x365 basis.
- f. Visitor or other third-party access to all PFL information processing facilities containing sensitive information shall be controlled.
- g. Except for publicly accessible/open areas, all visitors shall be escorted by an employee.
- h. The date and time of entry and departure of visitors and third-party personnel and the purpose of visit shall be recorded in a visitor's register.



- i. In case, electronic access card is misplaced, lost or stolen, the concerned person shall immediately notify the Facilities management. The Facilities management shall then deactivate the lost electronic access card immediately.
- j. Non-returned electronic access cards for personnel (employees, contractors or third-party personnel) leaving the company or terminated employees, shall be deactivated.

11.4 Securing Offices, Rooms and Facilities

- a. All PFL information processing facilities shall always remain secured.
- b. Appropriate level of security controls shall be implemented to prevent unauthorised access to information processing facilities and facilities hosting critical equipment.
- c. The information processing facilities shall comply with the local environment, health and safety laws and regulations.

11.5 Protecting Against External and Environmental Threats

- a. Facilities management shall provide and adequately maintain fire detection and suppression, power conditioning, air conditioning, humidity control, flood detection measures and other computing environment protection systems in all facilities.
- b. Facilities management shall implement adequate power supply mechanisms to ensure continuous power supply.
- c. Facilities management shall create and implement emergency evacuation plans including the formation of an Emergency Response Team (ERT) to ensure emergency evacuation.
- d. Facilities shall have emergency exit routes.
- e. Evacuation plans shall be documented and displayed throughout facilities.
- f. The Facilities management shall ensure that the evacuation plan is reviewed and tested.
- g. Facilities shall undergo evacuation drills. The results of the drill shall be documented.

11.6 Working in Secure Areas

- a. Access to all the restricted areas shall be provided to authorised personnel on need to have basis only after the requisite approval is obtained.
- b. Physical movements in such areas shall be recorded via electronic surveillance system at all times.
- c. Visitor access shall be pre-approved, restricted and recorded. All the visitors shall be escorted at all times.
- d. Photographic, video, audio or other recording equipment, such as cameras in mobile devices shall not be allowed in secure areas.

11.7 Public Access, Delivery, and Loading Areas

- a. A secured intermediate holding area shall be used for all supplies, equipment and other deliveries.

- b. It shall be ensured that all areas, where loading/unloading of items is done are:
 - Monitored and equipped with the appropriate physical security controls during these activities.
 - Confined to the authorised personnel only during these activities.
- c. The movement of all incoming and outgoing items shall be documented, and incoming items shall be inspected for potential threats.

11.8 Equipment Security

Objective: To prevent loss, damage, theft or compromise of assets and interruption to the organisation's activities.

11.9 Equipment Siting and Protection

- a. All equipment shall be protected against environmental threats and unauthorised access.
- b. All equipment shall be appropriately located, and security controls be implemented to reduce the risk of potential threats (such as theft, fire, smoke, electrical supply interference) for their continued operations.
- c. All the unattended equipment such as servers, network, and wireless and telecom devices shall be placed in secure enclosures.
- d. Environmental protection controls shall be identified and implemented for the safety of the equipment.

11.10 Supporting Utilities

- a. All information processing facilities shall have the requisite supporting utilities to ensure continuity of the services without impacting confidentiality, integrity and availability of the same and to provide a safe working environment to the employees.
- b. All supporting utilities, such as electricity, water supply, sewage, heating/ventilation and air conditioning, are in appropriate condition.
- c. Uninterruptible power supply (UPS) systems and generators are installed to support controlled shutdown or continued functioning of equipment supporting critical business operations.
- d. An alarm system to highlight malfunctions in the supporting utilities is installed.
- e. Adequate contacts are in place with other authorities including utilities, emergency services, health and safety departments.
- f. A preventive maintenance exercise for the utility equipment is carried out at scheduled intervals ensuring their continued availability and integrity.

11.11 Equipment Maintenance

- a. All equipment shall be protected from power failures and other disruptions caused by failures in supporting utilities.



- b. All relevant functional units shall ensure that preventive maintenance for all IS and telecom devices is carried out at regular intervals to ensure continuous availability of these systems.
- c. All information systems equipment used for production processing shall be maintained in accordance with the Original Equipment Manufacturers (OEM) recommended service intervals and specifications, with any repairs and servicing performed only by qualified and authorised maintenance personnel.
- d. The Annual Maintenance Contracts (AMCs) for all hardware and software products, if applicable, shall be monitored and reviewed.

11.12 Security of Equipment Off-Premises

- a. Employees shall use PFL provided assets such as laptops, tablets, cell phones and other hardware in a secure manner even outside PFL campus and/or information processing facilities (hotels, airports etc.).
- b. Any media or equipment required to be moved outside the organization shall have a valid gate pass signed by authorized personnel. The outgoing and incoming media details shall be recorded in the asset movement register.

11.13 Secure Disposal or Re-Use of Equipment

- a. Equipment shall be disposed in an environmentally responsible manner, taking account any recycling facilities provided by manufacturers, local authorities or commercial organisations.
- b. All employees, contractors and third-party personnel shall ensure that information systems are disposed of after obtaining approval from authorised personnel.
- c. Sensitive data and licensed software shall be removed from the media prior to its disposal.
- d. The procedure for secure disposal of media shall apply to all devices owned by PFL and also to the disposal of storage media (such as Hard Disk Drives) in machines (such as laptops) that are hired by PFL.
- e. All storage media that of shall properly disposed using effective means prior to disposal, whereby the data cannot be retrieved.
- f. If it is possible to "definitely state" that there is neither sensitive data in a storage media nor the storage media is being transferred within PFL, then software overwrite can be used to clean the storage media, instead of degaussing.
- g. Before sending any equipment for repair, it shall be sanitized to ensure that it does not contain any sensitive data.

12 Information Security Risk Assessment

Overview:

Risk management is the process of identification, analysis, evaluation and treatment of risks. Risk is a combination of the probability of an event and its consequence. The risk management process involves analysing the threats that information assets are subjected to and determining the impact that the loss of confidentiality, integrity, and availability may have on the business operations of an organisation.

The process of risk management is an ongoing activity that is dynamic in nature and responds to changes in the internal and external environment of the organisation over a period of time. Therefore, while risk management is a point in time exercise, an organisation's ability to manage its risk continuously (in response to an ever-changing environment) is a key challenge. Therefore, performing information security risk management on an ongoing basis is important for PFL.

Risk assessments can be either qualitative or quantitative in nature. However, from the perspective of defining and implementing security controls, the risk methodology adopted is the qualitative approach.

12.1 Risk Management Process

Objective: To ensure that the security and privacy risks associated with an information asset are assessed as per the guidelines mentioned in this document and to determine the safeguards to be put in place to reduce the level of risk or to contain the impact of a security and privacy breach

12.2 Risk Assessment

A formal risk assessment shall be carried out and subsequently reviewed and updated on a periodic basis by the management in order to determine the security and associated risks to information assets.

The risk assessment involves identification of information assets, and an in-depth assessment of threats and associated vulnerabilities to these identified assets. It also identifies effectiveness of controls in preventing a threat from exploiting the identified vulnerabilities, probability of occurrence of a potential threat damaging the asset and a measure of the impact in terms of confidentiality, integrity and availability of the information asset to the business.

The risk assessment process includes the following phases:

- Risk Identification
- Risk Evaluation
- Risk Treatment

12.3 Risk Identification

- a. Risk identification is the process of identifying assets and associated threats and vulnerabilities, probability of occurrence of a threat exploiting the vulnerability of the asset and resulting consequences (impact) to the assets.

12.4 Risk Evaluation

- b. Risk evaluation is the process of comparing identified risks and evaluating them against the risk criteria already established, if any. The risk evaluation shall involve determining the effectiveness of existing controls,



analyzing the risks in terms of impact and LHO in the context of existing controls and estimating the residual risks.

12.5 Risk Treatment

- c. Risk treatment is the process of determining the treatment options for the identified risks. The risk treatment includes the following key activities:
 - a. Identify the Risk Treatment Options and develop the Risk Acceptance Criteria

Develop Risk Treatment Plan and assign responsibilities for implementation of selected Risk Treatment options.

- Determine the Risk Treatment Option for all identified risks.
- Follow up on the implementation of the Risk Treatment Plans.
- Reassess the risks for all the asset classes on a periodic basis.

13 Cloud Computing

With the increasing adoption of digitization and faster turnaround times for business outcomes, adopting cloud as a strategic approach to meet the business requirements is the need of the hour.

Due diligence covering strategic, technical, security, contractual & compliance should be established prior to considering migrating or setting up any digital asset onto the cloud. Relevant business cases covering all the above aspects should be prepared, that shall be reviewed and approved by all relevant stakeholders prior to implementation on Cloud.

Accountability of Cloud security lies with PFL stakeholders. They must keep PFL Information Security team involved and always apprised on the status and development for their respective areas on the cloud.

14 Artificial Intelligence (AI) Security Policy

Artificial Intelligence (AI) technologies are reshaping organizational operations, offering enhanced efficiency, decision-making capabilities, and innovation. However, their adoption introduces new risks related to information security, data privacy, governance, and regulatory compliance. This policy establishes controls and governance mechanisms for the responsible use of AI technologies within the organization.

This policy outlines the security controls for the usage and integration of Artificial Intelligence (AI) technologies within the organization. It aims to ensure the confidentiality, integrity, availability, privacy and regulatory compliance of AI systems, including adherence to applicable laws. This policy applies to:

- All on-roll and Off-role employees using AI tools
- Teams using AI tools for development related work
- Business units adopting AI for process enhancement or automation

14.1 Security in adoption and integration of AI

Data Security

- PFL should put in place guardrails, especially when using third party AI models, to ensure that customer data, PFL sensitive data and other confidential remains within secure environment under the control of PFL.
- Security controls like access control, audit trails, logging & monitoring, and vulnerability assessments and others shall also be applicable to AI-based tools / systems.
- Due diligence and information security assessments shall be done during testing, pre-deployment phase as well as periodically even after AI tools have been deployed.
- Any experimentation, functional enhancement testing with AI solutions must be done in controlled environments,
- Clear ownership and governance must be established and documented for all AI systems and tools with defined roles and responsibilities.
- The use of third-party, or off-the-shelf AI tools (e.g., generative AI applications) for official purposes shall be governed by PFL policies.

Incident Management

- Incident related to AI tools can result in significant financial, operational, or reputational loss, such incidents must be reported to Information security team immediately.

Business Continuity

- BCP/ DR requirements for all critical AI systems which are being used for critical processes shall be governed by PFL BCM policy if applicable.
- BCP/DR drills and simulations drills for all such AI systems shall be conducted as per BCP-DR requirement if applicable and as per applicable regulatory guidelines.

Data Privacy

- Since AI systems often collect and process huge amounts of data, it is crucial that whenever possible sensitive data such as PII shall be anonymized till the extent possible to avoid unauthorized data disclosure in case of data breach or cyber incident.

Third party risk

- AI implementations often rely on external vendors, cloud service providers, and technology partners to supply, maintain, and/or operate AI systems, they can expose PFL to risks such as software defects, non-compliance with regulatory obligations, breaches of contractual terms etc.
- Due diligence and risk assessments shall be conducted during on-boarding as well as periodically to verify service provider's security controls and ensure compliance with regulatory guidelines.

Data Localization

- All testing/ experimental, pre-production and production data used in AI tools and AI model training should reside in the geographical boundary of India, especially when cloud services and third-party AI service providers are involved.
sFor detailed operational procedures, roles, and responsibilities, kindly refer to the AI Security SOP document.

Classification | INTERNAL

15 Definition

PFL	:	Poonawalla Fincorp Limited
CRO	:	Chief Risk Officer
CISO	:	Chief Information Security Officer
CIO	:	Chief Information Officer
CTO	:	Chief Technology Officer
ITSC	:	IT Strategy Committee
IT	:	Information Technology
NDA	:	Non-Disclosure Agreement

----- End -----